What Do Australian Businesses Need To Know About The GDPR?

by **Abinaja Yogarajah** 11 January 2025 10 min read

eCommerce Employment Law Data & Privacy

CONTENTS

- Does The GDPR Apply To Australian Businesses?
- Key GDPR Principles And Obligations
- What Rights Do Individuals Have Under The GDPR?
- How Does The GDPR Interact With Australia's Privacy Laws?
- Practical Steps To Get GDPR-Ready (Checklist)
- Common GDPR Scenarios For Australian Businesses
- Key Takeaways

If your business has a website, runs online ads, or sells services internationally, you've probably heard of the General Data Protection Regulation (GDPR). Even if you're based in Australia, the GDPR can still apply - and the penalties for getting it wrong can be significant.

Need help for your business?
Get a fixed-fee quote - no obligation.
Get a Free Quote

we'll explain when the GDPR applies, what it requires, how it compares to Australia's Privacy Act, and the concrete steps you can take to get compliant.

Does The GDPR Apply To Australian Businesses?

You don't need to be located in Europe to be covered by the GDPR. It applies extraterritorially - meaning Australian organisations can be caught if they target or track people in the European Union (EU) or United Kingdom (UK) (the UK has a near-identical regime often called "UK GDPR").

When The GDPR Applies

- **Offering goods or services to people in the EU/UK:** This includes selling products, subscriptions, apps, or services to EU/UK residents - even if the service is delivered digitally from Australia. Pricing in euros, shipping to EU countries, or localising your site for EU languages are common indicators.
- **Monitoring behaviour of people in the EU/UK:** Using analytics, cookies, or other tracking to profile or observe users in the EU/UK can trigger GDPR obligations - even if you don't make a sale.

If neither of these applies and you only serve Australian customers, the GDPR may not apply. However, many Australian privacy best practices overlap with GDPR - so it's worth understanding the standards if you plan to grow overseas.

Who Is A "Controller" And Who Is A "Processor"?

Need help for your business?
Get a fixed-fee quote - no obligation.
Get a Free Quote

cloud host or marketing platform). You can be both, depending on the activity. This matters because controllers have primary compliance responsibility and must put contracts in place with processors.

Key GDPR Principles And Obligations

The GDPR is built on clear principles. If you keep these front-of-mind, your compliance program will have a strong foundation.

Lawful Bases For Processing

Every use of personal data needs a lawful basis. The most common are:

- **Consent:** Freely given, specific, informed and unambiguous. Pre-ticked boxes don't count.
- **Contract:** Processing necessary to perform a contract with the individual (e.g. delivering an order).
- **Legitimate interests:** Your business purpose balanced against the individual's rights (requires a reasoned assessment).
- Less common bases include legal obligation, vital interests and public task.

Map each data use to a lawful basis and document your reasoning. This is part of the GDPR's "accountability" principle.

Transparency And Privacy Notices

You must clearly explain what you collect, why you collect it, who you share it with, where it's stored and for how long, plus how people can exercise their rights. This is typically done in a Privacy Policy and just-in-time notices (e.g. a brief message near a form).

Need help for your business?
Get a fixed-fee quote - no obligation.
Get a Free Quote

Only collect what you need, use it for the purpose you stated, and don't keep it longer than necessary. Having a clear schedule for deletion or anonymisation supports compliance and reduces risk.

Cookies, Analytics And Direct Marketing

Many websites rely on analytics, advertising cookies, and email marketing. Under the GDPR (and the EU ePrivacy rules), you generally need prior consent for non-essential cookies and tracking. This is why you see granular cookie banners in Europe.

For email campaigns, record how you obtained consent or the lawful basis you rely on, and always provide an easy opt-out. It's also important to ensure your marketing complies with Australia's spam and consumer rules, as well as the EU regime. Our guide to email marketing laws is a useful reference here.

If you use cookies, a concise banner and a detailed Cookie Policy can help you meet the transparency and consent requirements.

Working With Vendors: Processors And Contracts

If you use third-party providers (like cloud storage, CRM tools, or marketing platforms) to handle personal data, you must have a contract containing specific GDPR clauses. This is commonly called a Data Processing Agreement (DPA). It sets out security, sub-processor approval, breach notification, and data return/deletion at the end of the service.

International Transfers

Sending personal data from the EU/UK to Australia is a "restricted transfer" under the GDPR. If your EU users' data is stored in Australia (or accessed from Australia), you generally need an approved transfer mechanism, such

Need help for your business?
Get a fixed-fee quote - no obligation.
Get a Free Quote

need to check this and keep records.

Security And Breach Notification

You must implement appropriate technical and organisational measures (think encryption, access controls, training, incident response). If you suffer a data breach that risks harm to individuals, you may need to notify EU regulators within 72 hours, and sometimes affected individuals too.

A documented Data Breach Response Plan helps your team act fast and consistently under pressure.

Records, DPIAs And DPOs

- **Records of processing:** Keep a central record of your data flows, purposes, bases, recipients, retention and security. This is mandatory for many businesses and a best practice for all.
- **Data Protection Impact Assessments (DPIAs):** If a processing activity is likely high risk (e.g. large-scale profiling), conduct a DPIA to assess and mitigate risks before proceeding.
- **Data Protection Officer (DPO):** Some organisations must appoint a DPO (for example, if you conduct large-scale monitoring). Many Australian SMEs won't strictly need a DPO, but you should designate someone responsible for privacy compliance internally.

Children's Data

Processing children's personal data has extra requirements. Parental consent is often needed for online services offered directly to children under a certain age. If your product or marketing may reach young users, build this into your consent and verification processes early.

Need help for your business?
Get a fixed-fee quote - no obligation.
Get a Free Quote

People in the EU/UK have robust privacy rights, and you need processes to respond within set timeframes (usually one month).

- **Access:** Provide a copy of their personal data and information about how you use it.
- **Rectification:** Correct inaccurate or incomplete data.
- **Erasure ("right to be forgotten"):** Delete data in certain circumstances (for example, when you no longer need it or consent is withdrawn).
- **Restriction:** Limit how you use the data temporarily.
- **Data portability:** Provide data in a machine-readable format so it can be moved to another provider.
- **Objection:** Stop processing in certain situations (commonly direct marketing).
- **Automated decision-making:** Additional rights where decisions are made solely by automated means.

Make sure your systems and vendors can action these rights (for example, deleting data from backups, suppressing marketing lists, or exporting data in a suitable format).

How Does The GDPR Interact With Australia's Privacy Laws?

Australia's Privacy Act 1988 (Cth) and the Australian Privacy Principles (APPs) apply to many Australian businesses, especially if your annual turnover is over $3 million or you fall into certain categories (like handling health information). While there's overlap, the GDPR goes further in several areas.

Need help for your business?
Get a fixed-fee quote - no obligation.
Get a Free Quote

- Transparency, purpose limitation, and security are core in both regimes.
- Both require reasonable steps to protect personal information and to respond to access/correction requests.
- Both expect you to have clear policies and governance in place.

Key Differences

- **Lawful bases:** GDPR requires you to tie each processing activity to a specific legal basis. The Privacy Act is less prescriptive.
- **Consent standards:** GDPR has stricter consent rules, especially for cookies and direct marketing.
- **Individual rights:** GDPR includes portability, erasure and broader objection rights.
- **Breach notification:** GDPR has a tighter 72-hour regulator notification window. Australia's Notifiable Data Breaches scheme has different thresholds and timing.
- **International transfers:** GDPR imposes specific transfer mechanisms (like SCCs) for sending data outside the EU/UK.

If you're subject to both, aim for the higher standard to reduce complexity. This also positions you well for potential upcoming reforms to the Privacy Act. It's also practical to align your retention schedules with documented data retention laws considerations in Australia.

Practical Steps To Get GDPR-Ready (Checklist)

If the GDPR applies (or is likely to), here's a pragmatic approach to compliance. You can tackle these steps progressively - the important thing

Need help for your business?
Get a fixed-fee quote - no obligation.
Get a Free Quote

1) Map Your Data

- List the personal data you collect (names, emails, IP addresses, purchase history, device IDs, etc.).
- Identify where it comes from (website forms, checkout, support chats), where it's stored, who you share it with, and how long you keep it.
- Note which activities involve EU/UK individuals.

This forms the backbone of your Records of Processing and helps you spot risks, unnecessary collection, and international transfers.

2) Identify Your Lawful Bases

- Allocate a lawful basis to each processing activity and document your rationale.
- Where you rely on "legitimate interests," complete a brief balancing assessment.
- For consent-based processing (cookies, certain marketing), design clear opt-ins and easy withdrawals.

3) Update Policies And Notices

- Refresh your Privacy Policy to cover GDPR transparency requirements (purposes, recipients, international transfers, rights, retention, and lawful bases).
- Add just-in-time notices near forms and provide layered information (headline points first, more detail via links).
- Implement a cookie banner with real choices and a detailed Cookie Policy.

Need help for your business?
Get a fixed-fee quote - no obligation.
Get a Free Quote

- Sign a Data Processing Agreement with vendors that process personal data for you (hosting, analytics, CRM, email platforms).
- Check international transfer terms (for EU-Australia flows) - look for SCCs and ensure they are actually implemented.
- Review customer and partner contracts to ensure your privacy representations are accurate and achievable.

5) Build Security And Incident Response

- Apply sensible security controls: MFA, encryption at rest/in transit, role-based access, regular patching, and vendor risk reviews.
- Document an incident response process in a Data Breach Response Plan and run a tabletop exercise so the team knows what to do.
- Set up breach thresholds and communication templates for regulators and affected individuals.

6) Operationalise Rights Requests

- Enable easy access, correction, deletion, and objection requests (ideally via a simple online form and support process).
- Make sure your team and vendors can find, export, or delete data within practical timeframes - including from backups or archives where feasible.

7) Conduct DPIAs Where Needed

- For new or high-risk projects (AI profiling, location tracking, large-scale sensitive data), do a quick risk assessment before launch.

Need help for your business?
Get a fixed-fee quote - no obligation.
Get a Free Quote

8) Train Your Team And Review Regularly

- Provide role-based privacy training (customer support, marketing, product, engineering).
- Schedule periodic reviews of your policies, consents, and vendor DPAs - privacy is not “set and forget.”

9) Consider A Practical GDPR Toolkit

If you want a structured, faster path to compliance, Sprintlaw offers a tailored GDPR Package that brings together the key policies, contracts and guidance you’ll need to operationalise these steps.

Common GDPR Scenarios For Australian Businesses

To make this concrete, here are a few scenarios we see often - and what they mean from a GDPR perspective.

Australian SaaS With EU Customers

You sell a software subscription globally. You process EU user accounts, billing, and usage analytics. You’re a controller for your marketing website and a processor/controller within your app, depending on features. You’ll need: a GDPR-compliant Privacy Policy, cookie consent, DPAs with your infrastructure providers, SCCs for EU-AU transfers, rights request processes, and robust security and breach response.

Ecommerce Store Shipping To Europe

Need help for your business?
Get a fixed-fee quote - no obligation.
Get a Free Quote

GDPR-consistent transparency, appropriate consent for non-essential cookies/ads, clear opt-outs for marketing, and DPAs with your fulfilment and email platforms. Keep your retention schedule aligned with shipping, returns and warranty timeframes, reflecting your approach to data retention laws more broadly.

Australian Marketer Running EU Campaigns

You manage campaigns for EU audiences. Make sure lists are collected with valid consent or another lawful basis, document your role (controller/processor), and ensure your client contracts allocate GDPR responsibilities clearly. Revisit your cookie consent flow and your understanding of the EU rules on direct marketing alongside Australia's email marketing laws.

Key Takeaways

- The GDPR can apply to Australian businesses that offer goods or services to, or monitor, people in the EU/UK - location alone doesn't determine coverage.
- Core GDPR duties include mapping your data, choosing a lawful basis, being transparent, minimising collection, securing information, and responding to rights requests.
- Get your paperwork in order: a clear Privacy Policy, a practical Cookie Policy, robust DPAs with processors, and a tested Data Breach Response Plan.
- If you transfer personal data from the EU/UK to Australia, ensure you have a valid transfer mechanism (often via SCCs) and keep records.

Need help for your business?
Get a fixed-fee quote - no obligation.
Get a Free Quote

- Treat GDPR as an ongoing program: train your team, review vendors, and refresh policies regularly as your business evolves.

If you'd like a consultation on GDPR compliance for your Australian business, you can reach us at 02 8311 1232 or team@sprintlaw.com.au for a free, no-obligations chat.

Abinaja Yogarajah the legal operations lead

Abinaja is a the legal operations lead at Sprintlaw. After completing a law degree and gaining experience in the technology industry, she has developed an interest in working in the intersection of law and tech.

Meet Our Lawyers for Employment Law

Aidan Watt
Lawyer

Alex Solo
Co-Founder

Sprintlaw's expert lawyers make legal services simple and accessible for business owners. We're one of the fastest growing law firms in Australia and operate entirely online.